

Rapport JSON de vulnérabilités API

Objectif

Vous devez auditer les 5 endpoints API fournis pendant l'exercice et remettre un unique fichier JSON décrivant toutes les vulnérabilités que vous avez réellement identifiées.

Vous pouvez utiliser les outils de votre choix, y compris des assistants IA et des agents de pentest automatisés. Vous restez responsable du contenu rendu: chaque finding doit être vérifiable, reproductible et rattaché à un endpoint précis.

Livrable attendu

Remettez un fichier nommé `rapport-vulnerabilites.json`.

Le fichier doit être un JSON valide encodé en UTF-8. Aucun Markdown, commentaire, capture d'écran encodée en base64 ou texte hors JSON ne doit être ajouté.

Format JSON

```
{
  "student": {
    "name": "Nom Prénom",
    "email": "prenom.nom@example.com",
    "group": "M1"
  },
  "target": {
    "base_url": "https://cible.example",
    "tested_at": "2026-05-24T14:30:00+02:00",
    "scope": [
      "GET /api/events",
      "GET /api/users/{id}",
      "GET /api/invoices/{id}",
      "POST /api/profile",
      "POST /api/preview-url"
    ]
  },
  "findings": [
    {
      "endpoint": "METHOD /api/endpoint",
      "category": "categorie_du_constat",
      "severity": "critical|high|medium|low|info",
      "title": "Titre court du constat",
      "description": "Description précise du comportement observé.",
      "evidence": {
        "request": "Requête minimale permettant d'observer le comportement.",
        "response": "Extrait utile de la réponse ou du résultat observé."
      },
      "impact": "Impact sécurité concret.",
      "reproduction_steps": [
        "Étape 1",
        "Étape 2",
        "Étape 3"
      ],
      "remediation": "Correction recommandée."
    }
  ]
}
```

Règles de rédaction

- Ajoutez un objet dans `findings` pour chaque vulnérabilité distincte trouvée.
- Ne dupliquez pas le même constat avec une reformulation différente.
- L'endpoint doit être écrit sous la forme `METHOD /chemin`, par exemple `GET /api/example`.
- `severity` doit contenir une des valeurs suivantes: `critical`, `high`, `medium`, `low`, `info`.

- `evidence` doit permettre de vérifier le finding sans interprétation vague.
- `reproduction_steps` doit permettre de reproduire le comportement depuis un environnement propre.
- Si vous ne trouvez aucun finding, rendez quand même le JSON avec `"findings": []`.

La note dépendra de la présence de constats corrects, précis et reproductibles dans le JSON rendu.